

Departamento de Engenharia Informática

SWitCH Cyber - Pós-Graduação em Segurança de Informação, Cibersegurança e Privacidade

Arquitetura, Desenho e Desenvolvimento de Software Seguro (ADDSS) · Professor Paulo Baltarejo Sousa

Academic Year 2025/2026

M2: Security Assessment - TutorialWS

Group 3

Presentation Agenda

15-minute structured assessment · 7 report sections

01 Application Overview

Architecture · MVC components · Technology stack

02 Threat Modelling (OWASP TM)

Step 1: Scope · Step 2: STRIDE · Steps 3-4: Risk & Assessment

03 Static Analysis

SpotBugs (SB-01–09) · Manual review · 30 issues in 7 files

04 Dynamic Analysis

Postman (8 scenarios) · OWASP ZAP 2.17.0 (10 alerts)

05 Vulnerability Summary & ASVS

OWASP Top 10:2025 · ASVS Level 2 Gap Analysis

06 Mitigation Strategies

9 findings · CVSS-scored · implementation guidance

07 Conclusion & Recommendations

Three-layer validated assessment · Prioritised remediation plan

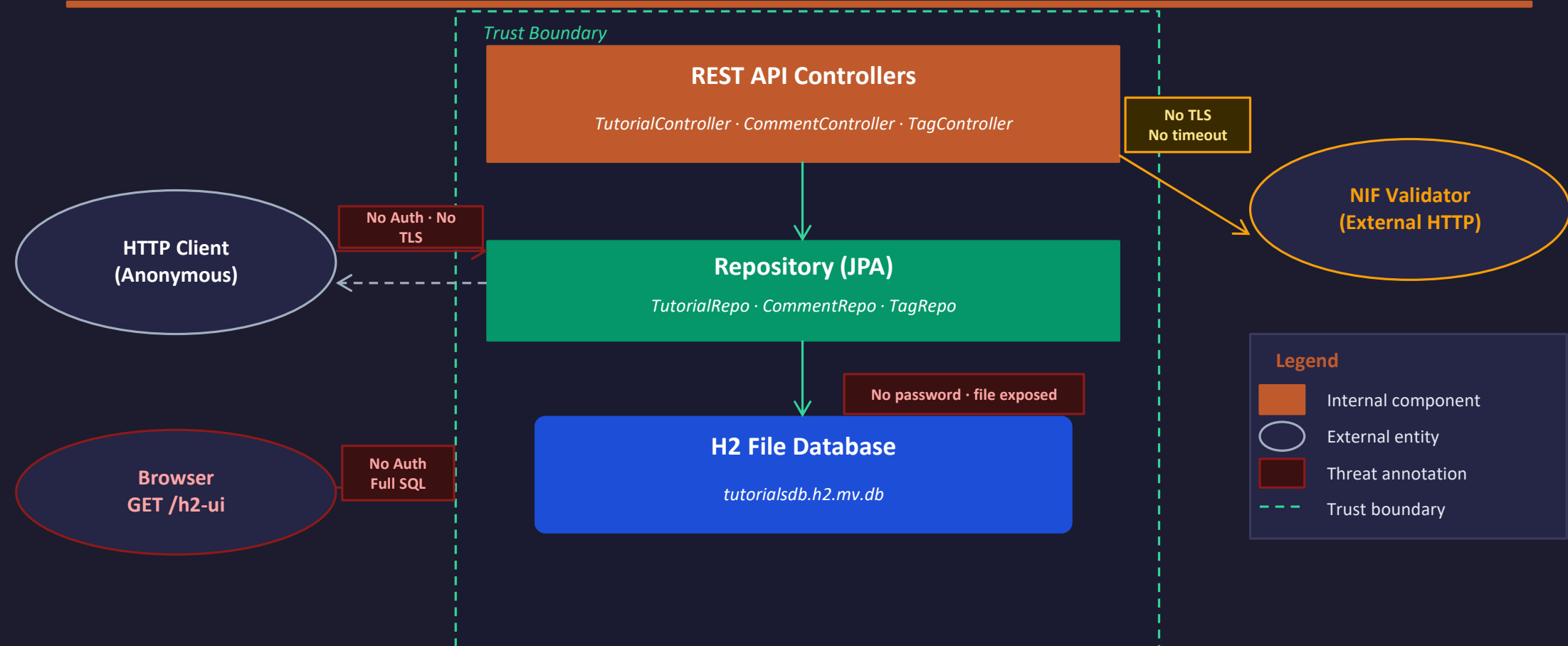
01

Application Overview

TutorialWS REST API · Spring Boot 2.6.7 · Java 11

1 - Application Overview

Architecture · Trust boundaries · Key threats at interconnection points



02

Threat Modelling

OWASP TM Framework · STRIDE · DREAD · ASVS v4

2 - Step 1: Scope (1/2) · Entry Points

19 HTTP endpoints across 3 controllers · All unauthenticated

TutorialController · /api/tutorials

GET	/api/tutorials
GET	/api/tutorials/{id}
GET	/api/tutorials/published
POST	/api/tutorials
PUT	/api/tutorials/{id}
DELETE	/api/tutorials/{id}
DELETE	/api/tutorials

CommentController · /api/comments

GET	/api/tutorials/{id}/comments
GET	/api/comments/{id}
POST	/api/tutorials/{id}/comments
PUT	/api/comments/{id}
DELETE	/api/comments/{id}
DELETE	/api/tutorials/{id}/comments

TagController · /api/tags

GET	/api/tags
GET	/api/tags/{id}
GET	/api/tutorials/{id}/tags
GET	/api/tags/{tagId}/tutorials
POST	/api/tutorials/{id}/tags
PUT	/api/tags/{id}
DELETE	/api/tags/{id}
DELETE	/api/tutorials/{id}/tags/{tagId}

H2 Console

GET	/h2-ui
-----	--------

2 - Step 1: Scope (2/2) · Exit Points · Assets · Trust Levels · Dependencies

4 exit points · 7 assets · 5 external dependencies · 6 trust levels

Exit Points

HTTP GET

pbs.dei.isep.ipp.pt:8080

/nifs-app/nifs/{id}

DB Write

tutorialsdb.h2.mv.db

save() · delete()

DB Read

tutorialsdb.h2.mv.db

findAll() · findById() · findBy*()

H2 Console

localhost:8080 - browser

GET /h2-ui

Assets

Tutorial data

Titles, descriptions, published state, tags

Comment data + NIFs

Comments + taxpayer numbers (PII)

Tag data

Tags associated with tutorials

H2 database file

tutorialsdb.h2 - all application data

Application source code

Spring Boot app, hardcoded URLs & config

application.properties

DB credentials, H2 console path

Application availability

REST API uptime - no rate limiting

External Dependencies

H2 Database v2.1.210

Embedded in JVM process

NIF Validation Service

pbs.dei.isep.ipp.pt:8080

Spring Boot 2.6.7

Maven Central / pom.xml

Spring WebFlux / Project Reactor

spring-boot-starter-webflux

H2 Console Web UI

Embedded servlet container · /h2-ui

Trust Levels

Anonymous User

Any HTTP client on port 8080 - full access to all endpoints

API Consumer

Application/user making REST calls - no distinction from TL-01

Database Administrator

/h2-ui user - equivalent to TL-01 (unprotected)

External NIF Service

pbs.dei.isep.ipp.pt:8080 - no auth, no cert. validation

Application Process (JVM)

Spring Boot process - full R/W on tutorialsdb.h2

System Administrator

Intended privileged role - NOT IMPLEMENTED

2 - Step 2: STRIDE Threat Analysis

14 threats · 6 categories · 3 Critical · 5 High · 5 Medium · 1 Low

STRIDE	Category	Threat IDs	Description	Impact
S	Spoofing	ST-01, 13	Zero authentication - any client impersonates any user on all 19 endpoints	HIGH
T	Tampering	ST-02, 09, 12	DELETE /api/tutorials wipes entire DB · No @Valid on any request field	CRITICAL
R	Repudiation	ST-14	No audit logging - no operations can be traced or reconstructed	MEDIUM
I	Info Discl.	ST-03, 04, 05, 10	H2 Console public · Blank DB password · No TLS · NIF URL hardcoded	CRITICAL
D	DoS	ST-07, 08, 11	No rate limiting · Optional.of(null) NPE · WebClient without timeout	HIGH
E	Elev. Priv.	ST-06	PUT /comments/{id} - no ownership check, any caller edits any comment	HIGH

2 - Steps 3 & 4: Countermeasures, Risk Ranking & Assessment

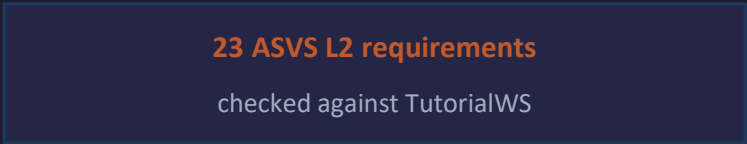
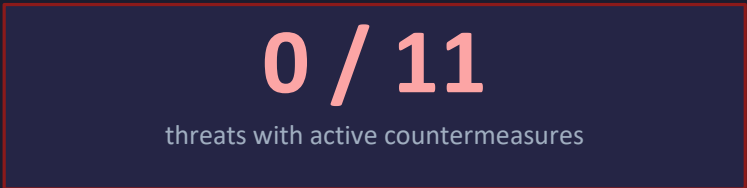
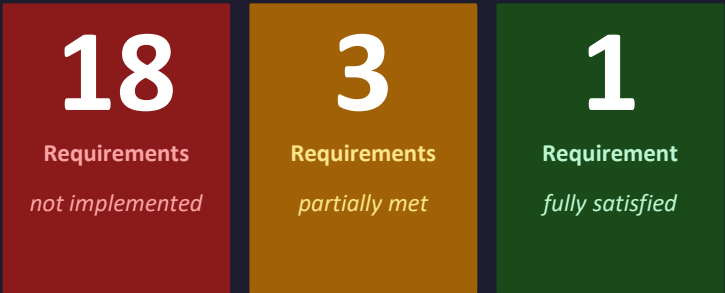
DREAD prioritisation · ASVS v4 · 0 of 11 countermeasures implemented

DREAD Risk Ranking

Threat	Prob.	Impact	Ease	Priority
H2-UI exposed + No auth on all endpoints	High	Critical	Very Easy	CRI
DELETE /api/tutorials unprotected	High	Critical	Very Easy	CRI
Empty DB password in config	Medium	High	Easy	HIG
No rate limiting - DoS	High	High	Easy	HIG
Editing other users' comments	High	High	Easy	HIG
No input validation on any field	Medium	Medium	Moderate	MED
Hardcoded NIF service URL	Low	Medium	Difficult	LOW

Step 4 - ASVS Level 2 Compliance

of 23 requirements checked



03

Static Analysis

SpotBugs (SB-01-09) · Manual Review (30 issues, 7 files)

3 - Static Analysis: SpotBugs & Manual Review

9 automated findings (SB-01–09) · 30 manual issues in 7 source files

SpotBugs - Automated

SB-01	Tutorial.java:72	NullPointerException, application crashes and Denial of Service (DoS)
SB-02	ErrorMessage.java:23	Mutable reference exposure , breaks entity encapsulation
SB-03	Comment.java:40	Mutable reference exposure, breaks entity encapsulation
SB-04	Tag.java:39	Mutable reference exposure, breaks entity encapsulation
SB-05	Tutorial.java:76	Mutable reference exposure, breaks entity encapsulation
SB-06	ErrorMessage.java:13	Mutable reference stored externally, encapsulation violation
SB-07	Comment.java:44	Mutable reference stored externally, encapsulation violation
SB-08	Tag.java:42	Mutable reference stored externally, encapsulation violation
SB-09	Tutorial.java:80	Mutable reference stored externally, encapsulation violation

All 9 findings: MEDIUM priority

Manual Review - Issues per File

File	Issues
CommentController.java ST-01,06,07,08,10,11	8
TutorialController.java ST-01,02,09,13	6
TagController.java ST-01,06,09,13	5
ControllerExcpHandler ex.getMessage+missing hdlrs	3
pom.xml Outdated SB + no dep scan	3
WebFluxConfig.java ST-10, ST-11	2
application.properties ST-03, ST-04	2

3 - Key Vulnerabilities: Critical & High

Source-confirmed · OWASP Top 10:2025 mapped · file and line

CRI

A01:2025

ST-01

All controllers (class level)

Zero Authentication on All Endpoints

No authentication or authorization mechanism exists, any user can freely access all application endpoints.

HIG

A07:2025

ST-04

application.properties:8

Blank Database Password in Plaintext

The database password is empty and stored in plaintext in the repository, allowing connections without any credentials.

CRI

A01:2025

ST-02

TutorialController.java:80

deleteAllTutorials() Unprotected

A single HTTP request wipes the entire database, with no identity validation or operation confirmation required.

HIG

A01:2025

ST-06

CommentController.java:64-68

Comment Ownership Not Verified

Any user can modify or overwrite other user's data without any identity check, enables impersonation and privilege escalation.

CRI

A02:2025

ST-03

application.properties:20

H2 Console Publicly Exposed

The database administration console is publicly accessible, allowing arbitrary SQL queries to be executed without authentication.

HIG

A06:2025

ST-08

CommentController.java:94-99

Silent Failure via Optional.of(null)

Internal errors are silenced by the exception handler, causing the API to return a success response even when the operation has failed.

04

Dynamic Analysis

OWASP ZAP · Postman · attack scenarios · Live confirmation

4 - Dynamic Analysis: Postman & OWASP ZAP

Postman scenarios · ZAP 10 alerts

Postman - Attack Scenario Summary

Missing Authentication

- No authentication required in any endpoint
- All HTTP methods return successful responses
- Sensitive operations (POST, DELETE) allowed without protection

H2 Console & Security Headers

- H2 database console publicly accessible
- No authentication or access restrictions
- Missing security headers

SSRF via NIF Service

- User input used in external HTTP requests
- No validation or sanitization of input
- Allows manipulation of outbound requests

Input Validation SQLi · XSS

- Application accepts malicious inputs
- XSS payloads stored and returned in responses
- Extra fields accepted

OWASP ZAP - 10 Alerts

1

HIGH

2

MEDIUM

4

LOW

3

INFO

HIG

Authentication Credentials over HTTP

MED

Content Security Policy header missing

MED

Missing Anti-Clickjacking header

LOW

Application Error Disclosure - stack trace

LOW

Server version leak: Tomcat/9.0.10

LOW

X-Content-Type-Options header missing

LOW

Timestamp disclosure (Unix format) in responses

05

Vulnerability Summary & ASVS

OWASP Top 10:2025 · 23 catalogued IDs · ASVS Level 2 Gap Analysis

5 - OWASP Top 10:2025 Classification & ASVS Level 2 Gap

23 unique IDs · 30 total issues · 1 OK · 3 Partial · 19 Missing

3

CRITICAL

ST-01, 02, 03

5

HIGH

ST-04 to ST-08

14

MEDIUM

SB-01-09 + ST-09-14

1

LOW

ST-13

A01 - Broken Access Control

8

No auth, SSRF, ownership violations · ST-01,02,03,06...

A02 - Security Misconfiguration

7

CORS, H2 console, timeouts, ddl-auto=update

A06 - Insecure Design

7

NPE design, pagination, forced published=true

A09 - Logging & Alerting Failures

2

ST-14 no logging · System.out.println dead code

A03 - Software Supply Chain

2

Spring Boot 2.6.7 CVEs · No dependency-check

A05 - Injection

2

No @Valid → SQLi, XSS, mass assignment

A07 - Authentication Failures

1

Blank DB password (ST-04)

A10 - Mishandling Exceptions (NEW 2025)

1

ex.getMessage() in HTTP response body

ASVS Level 2: 19 MISSING · 3 PARTIAL · 1 OK · Main gaps: V4.1 Access Control · V9.1 Communications · V5.1 Validation · V7 Logging

06

Mitigation Strategies

Security Implementation · CVSS-scored fixes · Code-level guidance

6 - Mitigation Strategies & Security Implementation

9 findings · CVSS-scored · Code-level fixes mapped to ZAP alerts and static findings

H2 Console Exposed

Disable: `spring.h2.console.enabled=false`; restrict to dev profile only

CRITICAL
CVSS 9.1

NPE in `removeTag()`

Guard: `if (tag != null) { tag.getTutorials().remove(this); }`

MEDIUM
CVSS 5.3

Application Error Disclosure

`server.error.include-stacktrace=never`; return only generic error messages

CRITICAL
CVSS 7.5

Missing Anti-Clickjacking Hdr

X-Frame-Options: DENY or CSP frame-ancestors 'none' on all pages

MEDIUM
CVSS 4.3

GeneratedValue / Sequence

Add `@SequenceGenerator` or switch to `GenerationType.IDENTITY` for H2

CRITICAL
CVSS 6.5

Tomcat Version Leak

`server.server-header= (blank) + spring.main.banner-mode=off`

LOW
CVSS 3.7

Missing CSP Header

Add Content-Security-Policy via Spring Security `HttpSecurity`

MEDIUM
CVSS 5.3

Timestamp Disclosure

Remove Date from ErrorMessage DTO; log internally only

LOW
CVSS 3.1

X-Content-Type-Options Missing

`http.headers().xssProtection().and().contentTypeOptions()` globally

MEDIUM
CVSS 5.1

07

Conclusion & Recommendations

Three-layer validated assessment · Prioritised remediation

7 - Conclusion & Recommendations

TutorialWS is critically deficient across all security layers - unfit for production

30

issues identified

3

Critical · exploitable

0

countermeasures active

19

ASVS L2 reqs. missing

Key Findings

- Zero authentication on all 19 endpoints (ST-01, CRITICAL)
- H2 console publicly accessible - full SQL (ST-03, CRITICAL)
- Mass-delete unprotected (ST-02), blank DB password (ST-04)
- XSS payloads stored unescaped, no @Valid on any field
- No rate limiting, no TLS, no audit logging
- 9 SpotBugs findings: mutable exposure across all entities

Priority Remediation

- Add Spring Security + JWT/OAuth2 - fixes ST-01, ST-02, ST-06
- Disable H2 console (spring.h2.console.enabled=false)
- Externalise DB password to env variable - remove from VCS
- Add @Valid + Bean Validation on all @RequestBody inputs
- Fix SSRF: sanitise NIF before WebClient.uri()
- Enforce HTTPS · Upgrade Spring Boot 2.6.7 → 3.x

Three independent methods converge on the same root causes - providing full cross-validation.

ASVS Level 2 Gap:

19 MISSING · 3 PARTIAL · 1 OK · Main gaps: V4.1 Access Control · V9.1 TLS · V5.1 Validation · V7 Logging